What I learned building an MCP gateway

for AI-agent tools

The interesting part was not the proxy. It was the trust boundary.

学

Niraven · No AI slop

Lesson 1

metadata is part of the attack surface

Agents read tool descriptions to decide what to do.
That means descriptions are not harmless documentation.

Lesson 2

approval is not enough

If the agent sees a poisoned tool before approval, the damage may already start in context.
Unsafe tools should be blocked before listing.

Lesson 3

trust needs memory

A server can change its tool descriptor after you first connected it.
Hashing descriptors gives you a baseline to compare against.

Lesson 4

logs are a product feature

When an agent touches real systems, you need to know what was called, why it was blocked, and what changed.
Also: redact secrets by default.

四

Lesson 5

local-first matters

Developers should be able to test agent security before sending anything to a hosted platform.
Small tools build trust faster.

五

The bigger idea

agents need infrastructure, not vibes

Security, audit, rate limits, credential boundaries, and human review are the bridge from demo to production.

結